Resumen de requisitos ADMIN

Corte ADMIN: 13 de octubre de 2026
Base documental: SRS versión 0.60 y `VALIDACION_ACTUAL.md`, actualizados al 15 de octubre de 2026.
Propósito: resumir el estado técnico de las ocho prioridades ADMIN, distinguir lo implementado de lo validado y proponer criterios concretos para revisar su cierre.

Este documento es una guía de revisión, no una aceptación contractual ni una certificación de producción. Los estados reflejan los requisitos y la evidencia descritos en el SRS y en VALIDACION_ACTUAL.md. `IV` significa implementado y validado dentro del alcance probado; `ISV`, implementado sin validación completa; `PAR`, parcial; `COR`, requiere corrección; y `PEN`, pendiente. Los porcentajes estimados del SRS no equivalen a porcentaje de cumplimiento validado.

La actualización del 13-10-2026 registra mejoras de interfaz y auditoría descritas abajo y una revisión de código/documentación de las ocho prioridades. No se elevan los estados a IV sin completar las pruebas y criterios de aceptación pendientes.

La ampliación de Reportes del portal documentada el 14-10-2026 no forma parte de la estimación de las prioridades ADMIN ni modifica su 67%.

La actualización del 15-10-2026 registra cambios del portal de empresa: `/gestion-cuentas`, perfil de empresa y responsables visibles para ADMIN en «Ver como empresa». La conversión `company` → `contract_admin` está permitida si queda otro `company` activo; la protección del último administrador se mantiene. Estos cambios no modifican el 67% histórico del corte ADMIN del 13-10. La invitación/aceptación de cuentas existentes y la validación visual final siguen pendientes; evidencia en `VALIDACION_ACTUAL.md`.

Resumen ejecutivo

#	Prioridad	Avance estimado	Estado actual	En síntesis
1	Dashboard global	**75%**	**PAR** — RF-DAS-01/02	Muestra contadores, acreditación, estados documentales y actividad por eventos. Falta aplicar y validar universos, denominadores y crecimiento de empresas/usuarios.
2	Gestión global de empresas	**90%**	**IV en alcance verificado; rechazo/casos límite pendientes** — RF-EMP-01/02	Tabla «Empresas (cuentas)» con industria y estado de cuenta; detalle de perfiles y responsables por contrato. Flujo normal de registro/aprobación verificado; falta validar rechazo y transiciones repetidas.
3	Buscador global	**55%**	**PAR** — RF-BUS-01/02	Botones despliegan listas por categoría; el backend exige ADMIN, pero no aplica permisos independientes por categoría/detalle. La autorización granular y la validación visual integral siguen pendientes.

#	Prioridad	Avance estimado	Estado actual	En síntesis
4	Métricas SaaS	**60%**	**PAR** — RF-MET-01/02/03	Hay métricas de clientes/usuarios, sesiones y series mensuales; baja actividad y uso/adopción aparecen en Salud. El tiempo de uso sigue siendo estimado y las revisiones de IA no equivalen necesariamente a documentos únicos.
5	Alertas y salud de clientes	**70%**	**Mixto:** RF-SAL-01 **PAR**; RF-SAL-02 **COR**; RF-SAL-03 **ISV**	Salud agrupa indicadores y detalle desplegable con explicaciones; falta validar umbrales y casos límite, totales/paginación y sondas operacionales que detecten fallos reales.
6	Usuarios, roles y permisos	**70%**	**PAR** — RF-USU-01/02	El listado ADMIN pagina usuarios y los cambios de alcance invalidan sesiones. El portal permite convertir `company` en `contract_admin` si queda otro `company` activo; siguen pendientes invitación/aceptación de cuentas existentes, historial completo de acceso y validación integral. El porcentaje es el estimado histórico del 13-10.
7	Auditoría y trazabilidad	**50%**	**PAR** — RF-AUD-01/02/03	Se auditan cambios seleccionados y la emisión de URL documental requiere motivo. Falta cobertura uniforme de autenticación, lecturas sensibles, operaciones y exportaciones; una URL emitida no prueba transferencia efectiva.
8	Seguridad y aislamiento	**62%**	**PAR** — RF-SEG-01/02/03, RNF-SEG-01	Hay controles de autorización, RLS y pruebas de aislamiento multiempresa. Falta demostrar mínimo privilegio en configuración equivalente a producción, cerrar el acceso excepcional y validar el alcance contractual, aplicado mayormente en API.

Estimación global del corte

Avance funcional ADMIN estimado: 67%, promedio simple de las ocho estimaciones anteriores: `(75 + 90 + 55 + 60 + 70 + 70 + 50 + 62) / 8 = 66,5%`, redondeado al entero más cercano. Cada prioridad pesa igual; no hay ponderaciones acordadas por criticidad o esfuerzo. No es un porcentaje de pruebas aprobadas, aceptación contractual ni preparación para producción.

El 67% describe cobertura funcional estimada. No se asigna un porcentaje de «listo para producción con datos sensibles»: los bloqueos P0 siguen abiertos, incluidos DEC-08, permisos por categoría/recurso, auditoría integral y evidencia de aislamiento/mínimo privilegio en un entorno equivalente a producción.

La cifra procede de revisión de código y documentación del 13-10-2026; en esa revisión no se ejecutaron pruebas ni recorrido visual. Los porcentajes anteriores del GAP (75–80% general y 55–65% para producción) son históricos y no deben presentarse como estimación actual.

1. Dashboard global

Estado: PAR — RF-DAS-01 y RF-DAS-02.

Lo que hace hoy

- Muestra cantidades de empresas, contratos, trabajadores y usuarios; distingue empresas aprobadas, trabajadores acreditados y usuarios con cuenta habilitada.
- Calcula acreditación ponderada por número de documentos obligatorios correctos de empresas aprobadas. También existe un promedio simple por empresa en la respuesta del backend, pero la pantalla presenta el porcentaje global ponderado.
- Muestra documentos pendientes, por vencer y vencidos.
- Presenta una serie mensual y un total de actividad expresados como eventos. No equivale a nuevas empresas, nuevos usuarios ni tiempo efectivo de uso.
- Algunos universos difieren: por ejemplo, el contador de usuarios excluye ADMIN y los documentos de la sección de estados no están restringidos a empresas aprobadas.

Sugerencias y criterios a considerar

1. Definir para cada contador su universo y exclusiones: estados de empresa, tipos de usuario, bajas, documentos obligatorios y si se incluyen empresas no aprobadas.
2. Etiquetar la acreditación como porcentaje ponderado por documentos y mostrar numerador/denominador o una explicación accesible.
3. Mantener actividad por eventos separada de crecimiento de adopción.
4. Propuesta de crecimiento: presentar empresas nuevas y usuarios nuevos por mes, con períodos y universos visibles; validar por separado la definición de alta de empresa/usuario y el tratamiento de registros desactivados.
5. Contrastar cada tarjeta y punto de serie con fixtures conocidos, incluyendo cero empresas/documentos, meses sin actividad y cambios de período.
6. No presentar métricas comerciales en el Dashboard; mantener MRR y crecimiento comercial en Métricas SaaS.

Para considerar el punto validado: definiciones acordadas y visibles, cálculos reproducibles con datos controlados, meses vacíos representados correctamente y ausencia de información personal/documental innecesaria. La propuesta de crecimiento requiere confirmación funcional antes de tratarla como alcance aprobado.

2. Gestión global de empresas

Estado: RF-EMP-01 **IV** para lectura; RF-EMP-02 **IV** para el flujo normal de registro y aprobación; rechazo y casos límite pendientes de validación.

Lo que hace hoy

- El listado recupera las páginas de empresas y presenta industria, estado de cuenta, estado operacional, contratos, trabajadores, actividad y acceso a la ficha agregada.
- Los trabajadores dados de baja no cuentan; el conteo de contratos no filtra por estado.
- El nivel de uso se calcula como cuentas con actividad registrada en los últimos 30 días dividido por las cuentas de la empresa. No representa duración ni necesariamente la proporción de cuentas habilitadas.

- La última actividad es el evento más reciente registrado y puede ser automático, no solo una acción humana.
- La ficha operativa presenta datos agregados, cuentas/perfiles, responsables por contrato y último evento/actor. No muestra RUT, email ni contenido documental en la vista revisada.
- La respuesta de detalle incluye `rejection_reason`, que la pantalla no utiliza; su necesidad para esta vista merece revisión.
- El registro crea empresa y primer usuario en estado pendiente; la aprobación manual de ADMIN cambia la empresa y el usuario a estado aprobado y mantiene el rol `company`. Se confirmó manualmente el 07-10-2026 que la aprobación genera una actualización auditada con la descripción `Cuenta approved por administrador , verificado por mi parte`. El endpoint de rechazo está implementado, pero no se informó una prueba manual de ese recorrido; transiciones repetidas y la validación de auditoría para otros resultados siguen pendientes.

Sugerencias y criterios a considerar

1. Conservar los conteos actuales solo si se aprueban expresamente las reglas de inclusión de contratos y trabajadores.
2. Etiquetar el porcentaje como “uso de cuentas con actividad en últimos 30 días” y mostrar su numerador/denominador; no llamarlo tiempo de uso.
3. Etiquetar “última actividad” como evento más reciente y aclarar que puede ser automático.
4. Retirar `rejection_reason` de esta respuesta si no existe una necesidad funcional de mostrarlo aquí; si se necesita, devolverlo solo en la vista/flujo autorizado que lo utiliza.
5. Validar el rechazo con motivo, las transiciones repetidas y el registro de actor/fecha/resultado; comprobar que una solicitud aprobada no se procesa de nuevo sin una regla definida.
6. Probar empresa sin usuarios, sin plan, sin eventos, sin contratos y sin documentos, además de paginación completa.

Para considerar el punto validado: lectura completa comprobada; etiquetas coincidentes con las fórmulas; datos sensibles minimizados; ficha correspondiente a la empresa elegida; y aprobación/rechazo con reglas y auditoría verificadas por pruebas y recorrido de interfaz. La aprobación normal y su evento de auditoría están verificados manualmente; el rechazo, las transiciones fuera del flujo normal y su auditoría continúan pendientes.

Ciclo de contratos (DEC-12, acordado): la operación ordinaria no debe eliminar físicamente contratos. Se distinguen desactivación temporal y finalización; ambos estados quedan en una sección histórica de solo lectura, se excluyen de totales y alertas operacionales, y no generan nuevas alertas/notificaciones. Las fechas originales siguen corriendo; al restaurar se recalcula el estado y se emiten solo avisos vigentes, sin reproducir los atrasados. `company` gestiona contratos propios, ADMIN globalmente y `contract_admin` solo consulta el histórico dentro de su alcance. Cada transición exige motivo. La implementación inicial está en código; falta validación integral (ver `VALIDACION_ACTUAL.md`).

3. Buscador global

Estado: PAR — RF-BUS-01 y RF-BUS-02.

Lo que hace hoy

- Busca empresas, contratos, trabajadores/personas, equipos y usuarios. Cada término parcial separado por espacios debe coincidir con datos del mismo resultado o su empresa asociada.

- Incluye búsqueda por RUT para empresas y sujetos; no asigna RUT propio a las cuentas de acceso ni devuelve el RUT en los resultados.
- Los botones por categoría despliegan las listas de resultados; el panel de referencias permite activar/desactivar empresas, cargos, contratos, tipos y marcas de equipo. Los filtros activos se muestran como chips removibles y se combinan con texto libre. El catálogo limita a 100 los valores dinámicos por categoría e indica si hay más; no muestra datos personales.
- La ficha agregada se abre debajo de la fila concreta elegida; solo se mantiene una abierta y se descartan respuestas tardías al cambiar búsqueda/fila o cerrar.
- El alcance de DEC-02 ya está acordado: cinco categorías, sin administradores de plataforma ni usuarios sin empresa, y fichas sin documentos. Sigue pendiente aplicar y validar permisos efectivos por categoría/detalle en el servidor.

Sugerencias y criterios a considerar

1. Definir la matriz actor × categoría × operación (búsqueda, ficha y campos visibles); aplicar autorización en servidor en cada solicitud.
2. Acordar el tratamiento de usuarios sin empresa y otras cuentas globales; no incluirlos/excluirlos silenciosamente.
3. Probar directamente la API como actor sin permiso, además de ocultar o deshabilitar controles en la interfaz.
4. Validar resultados multi-término, límites de resultados y del catálogo, categorías sin valores, activación/deselección de chips y cambios rápidos de búsqueda con respuestas tardías.
5. Mantener la minimización: sin RUT, documentos, tokens ni campos personales que no sean necesarios para identificar el resultado.

Para considerar el punto validado: autorización efectiva y negativa por API para cada categoría y detalle, resultados correctos y minimizados, y recorrido de interfaz probado para filtros, límites y apertura/cierre.

4. Métricas SaaS

Estado: PAR — RF-MET-01, RF-MET-02 y RF-MET-03.

Lo que hace hoy

- Hay indicadores de clientes activos, usuarios habilitados, DAU/WAU, actividad, revisiones de IA y series comerciales.
- Se cuentan sesiones vigentes usando refresh tokens.
- No existe aún una medición plenamente observada: el tiempo de uso actual es una estimación derivada de eventos/tokens. Se acordó telemetría real y como métrica principal minutos activos por usuario único con actividad (no duración promedio por sesión), bajo sesión autenticada, pestaña visible e interacción reciente; pausa tras cinco minutos inactivo y heartbeat cada 60 segundos.
- Hay documentos procesados y series mensuales, pero debe conservarse la distinción entre revisiones/intentos y documentos únicos.
- Salud de clientes presenta uso/adopción, usuarios por plan e industria y la clasificación de clientes sin usuarios, sin actividad o con baja actividad; sus riesgos se pueden desplegar por categoría.
- La conversión UF tiene un caso mensual probado, pero la respuesta aún requiere identificar fecha/fuente de UF y completar cobertura de períodos/monedas.

Actualización al 13-10-2026: los indicadores de uso/adopción, usuarios por plan/industria y clientes de baja actividad se encuentran en Salud de clientes, con secciones de detalle plegables y ayudas informativas. El tiempo de uso sigue siendo estimado y la telemetría acordada no está implementada. El endpoint global entrega un diccionario de definiciones. El panel etiqueta la duración como estimada y denomina "revisiones IA procesadas" a la métrica documental, sin presentarla como cantidad de documentos únicos. La clasificación sigue visible en la consola, ahora dentro de Salud. DEC-03 define DAU/WAU como usuarios únicos de empresas con actividad humana, sin ADMIN de plataforma ni eventos automáticos, usando `America/Santiago`. `past_due` se muestra aparte como pago atrasado y otros estados no activos/trial como «otro estado/no activo»; ninguno cuenta como cliente activo. El requisito sigue PAR: falta implementar y validar la telemetría acordada, además de la fuente/fecha de UF en cada respuesta. El heartbeat, la persistencia por sesión lógica y agregados diarios están acordados; la retención propuesta sigue sujeta a DEC-08. El período se selecciona entre día, últimos 7 días, últimos 30 días o mes calendario, usando días calendario inclusivos en `America/Santiago`. Las sesiones simultáneas se suman incluso si exceden el tiempo de reloj; el denominador es usuarios únicos con actividad en el período.

Sugerencias y criterios a considerar

1. Aprobar un diccionario de métricas: nombre, definición, fuente, ventana temporal, unidad y universo.
2. Diferenciar "cuentas habilitadas", "usuarios con actividad", DAU/WAU y "sesiones vigentes"; no usarlos como equivalentes.
3. Mantener la etiqueta "estimado" en tiempo/duración hasta que exista telemetría de sesión lógica acordada.
4. Definir si documentos procesados cuenta revisiones, resultados completados o documentos únicos; mostrar estados fallidos/en proceso por separado cuando corresponda.
5. Validar que Salud presente clientes de baja actividad con umbral, ventana temporal y casos sin usuarios/sin actividad.
6. Identificar fecha y fuente del valor UF; probar períodos mensual/anual, monedas admitidas, suscripción ausente y acceso denegado.

Para considerar el punto validado: diccionario aprobado, cifras contrastadas con fixtures, ausencia de datos diferenciada de cero y etiquetas/unidades/ventanas visibles y coherentes.

5. Alertas y salud de clientes

Estado: RF-SAL-01 **PAR**; RF-SAL-02 **COR**; RF-SAL-03 **ISV**.

Lo que hace hoy

- Calcula empresas con acreditación bajo el umbral existente, contratos con al menos tres documentos faltantes/vencidos, vencidos por empresa, morosidad y alertas activas.
- Hay límites en las listas de contratos (25) y alertas (50); la cantidad visible no siempre representa el total global.
- Salud de clientes presenta uso/adopción, distribución de usuarios por plan e industria y clientes con baja actividad; los detalles de riesgos se despliegan por categoría. No equivale al cierre de la prioridad: faltan validar clasificación, umbrales y tratamiento de listas limitadas.
- Existen panel y heartbeats operacionales, pero las sondas actuales no acreditan por sí solas disponibilidad real de API/workers.
- Procesos e incidentes tienen catálogo y acciones; ejecución manual inproc fue corregida/probada, pero falta recorrido distribuido Celery y trazabilidad correlacionable para investigar origen, operación y

resultado de incidentes.

Sugerencias y criterios a considerar

1. Acordar umbrales y ventanas para baja acreditación, “muchos pendientes”, inactividad y expiración de heartbeat.
2. Verificar en las vistas de salud que se distingan empresa sin usuarios, empresa con usuarios sin eventos, empresa sin documentos y empresa saludable, manteniendo coherencia con la clasificación de actividad presentada allí.
3. Mostrar total real, límite y mecanismo para recuperar el resto; no llamar “total” a la longitud de una muestra.
4. Probar casos justo por debajo, en y por encima de cada umbral y con más registros que el límite.
5. Comprobar que la API se detecta caída aunque el worker siga activo, y que cola vacía no se interpreta como worker disponible.
6. Ejecutar el flujo distribuido de Celery, reintento y cierre de incidente con actor, resultado, timestamps y correlación consultables; asociar empresas solo con evidencia verificable.

Para considerar el punto validado: umbrales acordados, casos límite probados, totales completos/paginación definidos y sondas capaces de detectar fallos reales en API, worker y base de datos.

6. Usuarios, roles y permisos

Estado: PAR — RF-USU-01 y RF-USU-02.

Lo que hace hoy

- Existen roles `admin`, `company` y `contract_admin`, alcance por empresa/contrato, listado y cambios administrativos de estado.
- El esquema actual vincula cada usuario a un único `company_id` y un único `contrato_id`; no permite membresías multiempresa ni varios contratos por cuenta `contract_admin`.
- En el portal, el registro solicita el nombre del usuario inicial y el perfil personal permite editar nombre, correo y contraseña. En «Ver como empresa», `/perfil` muestra el perfil de la empresa (nombre/correo editables; RUT/estado de solo lectura), no la identidad personal de ADMIN.
- `/gestion-cuentas` lista, busca, pagina y administra cuentas del tenant. En `/contratos`, ADMIN impersonando puede ver y gestionar responsables. Se puede asignar una cuenta `company` a un contrato con confirmación doble; el API conserva `ULTIMO_ADMINISTRADOR` si sería el último usuario `company` activo. Cuentas `contract_admin` existentes pueden reasignarse entre contratos.
- La regresión `tests/test_auth.py` + `tests/test_tenants.py` pasó 71/71 el 15-10-2026. La invitación/aceptación de una cuenta existente sigue pendiente; `/company/usuarios` crea usuarios nuevos y todavía no entrega el token de activación por email.
- La reactivación de cuentas e invalidación de sesiones anteriores está implementada y probada en pruebas aisladas. La migración v9 añadió `auth_version`; el esquema que exige actualmente la API es v11. No se afirma que cada entorno destino esté ya migrado.
- El listado administrativo de usuarios pagina los resultados; la navegación para universos mayores de 100 ya no es una brecha identificada.
- Backend valida que el contrato pertenezca a la empresa; la interfaz puede enviar combinaciones inválidas que backend rechaza.
- El último acceso se conserva en `last_login_at`, pero no sustituye un historial de autenticación.

- Desde la consola ADMIN, cualquier cambio de rol, empresa o contrato requiere confirmación contextual y motivo de al menos 12 caracteres. El backend audita actor, motivo y valores anteriores/nuevos e invalida sesiones; las pruebas específicas añadidas para este flujo están pendientes de ejecución.

Sugerencias y criterios a considerar

1. Aprobar la matriz de roles y permisos por empresa/contrato, incluyendo ADMIN y cuentas sin empresa.
2. Probar que cambiar cuerpo, URL o identificadores nunca permita acceder a otra empresa/contrato.
3. Asegurar que rol, empresa y contrato se guarden como una combinación coherente, sin cambios parciales cuando hay error.
4. Completar invitación/aceptación de cuentas existentes y activación por correo; la paginación del listado ADMIN está implementada.
5. Validar en navegador crear/editar/revocar/reactivar y cambiar rol/empresa/contrato; comprobar consecuencias, motivo obligatorio, auditoría, errores e identidad del destinatario.
6. Aplicar y validar la migración pendiente en el entorno destino antes de considerar operativo el flujo allí.
7. DEC-13 es una propuesta pendiente de aprobación del cliente: solicitud justificada por `company` o `contract_admin`; primero acepta el titular y luego ADMIN revisa. Ambas etapas deben completarse dentro de 14 días desde el envío; rechazo/expiración no cambian empresa/permisos. La alternativa recomendada es transferir la cuenta: retirar acceso de origen y asignar explícitamente el acceso de destino, sin heredar contratos. No implementar antes de la aprobación y validar aislamiento.

Para considerar el punto validado: matriz probada contra API, aislamiento empresa/contrato, ciclo completo de usuario y navegación sin omisiones; ninguna cuenta revocada conserva acceso o refresh válido.

7. Auditoría y trazabilidad

Estado: PAR — RF-AUD-01, RF-AUD-02 y RF-AUD-03.

Lo que hace hoy

- Hay eventos de actividad y auditoría para operaciones seleccionadas; la creación global de faenas es consultable.
- La consola de cambios de permisos registra actor, motivo y valores anteriores/nuevos para rol/empresa/contrato; la emisión de URL documental requiere motivo. La cobertura de otras operaciones sigue parcial.
- `last_login_at` y refresh tokens existen, pero no hay historial completo consultable de ingreso, fallo, cierre y revocación.
- La cobertura de catálogos y eliminaciones es incompleta; algunos borrados se registran con semántica de actualización.
- Reportes/exportaciones no tienen justificación uniforme, y lecturas de metadatos sensibles no se auditan de manera integral en todos los handlers revisados.
- DEC-11 acuerda exportación ZIP con un CSV por tipo de entidad en `/datos` y archivos en `/archivos/<tipo>/<id>/`, con nombre saneado y ruta en el CSV; incluye relaciones por defecto con opción de excluir categorías, motivo obligatorio y descarga inmediata sin conservar el paquete después de transferirlo. No hay topes funcionales; si falla, se cancela y borra el paquete incompleto, sin reintento automático, con opción de iniciar uno manual. Debe excluir secretos y auditarse por recurso. Viabilidad ante grandes volúmenes y pruebas de autorización/transferencia pendientes.

Sugerencias y criterios a considerar

1. Acordar catálogo de acciones auditables y campos: actor, sujeto afectado, operación, recurso, tenant/contrato, fecha UTC, resultado y motivo cuando aplique.
2. Registrar valores anteriores/nuevos para cambios de permisos sin almacenar contraseñas, tokens u otros secretos.
3. Diferenciar inequívocamente creación, actualización, eliminación física, desactivación, revocación y reactivación.
4. Incorporar eventos de autenticación exitosos/fallidos, cierre y revocación, correlacionados con sesión sin guardar credenciales.
5. Clasificar datos sensibles y definir cuándo se requiere motivo para lectura, URL, descarga o exportación.
6. Diferenciar solicitud de URL/generación de exportación de transferencia efectiva; para DEC-11 validar autorización por entidad y archivo, manejo de fallos/limpieza y determinar la evidencia de almacenamiento necesaria para acreditar una descarga.
7. Aplicar la retención inicial propuesta en DEC-08 y confirmar los plazos antes de producción; definir la matriz de consulta y auditar esos accesos.

Para considerar el punto validado: pruebas por operación que verifiquen actor/recurso/alcance/resultado, registro consultable incluso para actores sin empresa cuando corresponda, y ausencia de secretos/PII innecesaria.

8. Seguridad y aislamiento de datos

Estado: PAR — RF-SEG-01/02/03 y RNF-SEG-01.

Lo que hace hoy

- Hay filtros de autorización en la aplicación, dependencias y políticas RLS definidas.
- Algunas pruebas de aislamiento pasan, pero la configuración Compose revisada utiliza superusuario PostgreSQL, por lo que no demuestra que RLS proteja efectivamente a la aplicación.
- El alcance contractual se comprueba principalmente en la API; no se identificó política RLS contractual independiente en los scripts revisados.
- ADMIN conserva privilegio global; no hay flujo completo de acceso excepcional temporal/limitado a documentos sensibles.
- Existen guardas de configuración de producción y respuesta minimizada en áreas revisadas; despliegue, roles y secretos productivos aún requieren validación.
- Emisión de URL documental requiere motivo y controles de pertenencia, pero la auditoría de toda lectura sensible/exportación sigue parcial.

Sugerencias y criterios a considerar

1. Probar con empresas A/B y dos contratos de A: lectura, listado, modificación, eliminación, archivos y exportaciones; comprobar denegación cruzada.
2. Ejecutar pruebas con credenciales equivalentes a producción: API/worker sin superusuario, `BYPASSRLS` ni propiedad de tablas.
3. Aplicar DEC-10: exigir autorización de API y credenciales de mínimo privilegio; evaluar RLS contractual como defensa adicional solo si la propagación confiable del contexto y las pruebas para API, workers, ADMIN y agregados son viables. No presentarlo como implementado antes de validarlo.

4. Definir mínimo privilegio para ADMIN y acceso excepcional por capacidad, recurso y duración; selección de empresa no debe equivaler a acceso ilimitado.
5. Exigir actor, cuándo, recurso y motivo en accesos excepcionales; probar autorización/denegación por API.
6. Revisar dashboards, logs, respuestas, reportes y exportaciones para retirar RUT, documentos y PII que no sean necesarios.
7. Validar secretos, recuperación de cuenta, semillas demo y migraciones en configuración de producción aislada.

Para considerar el punto validado: pruebas negativas multiempresa/contrato en API, mínimo privilegio demostrado con roles reales y políticas RLS vigentes verificadas; si se adopta RLS contractual, añadir pruebas SQL directas y validación del contexto en workers, ADMIN, agregados y conexiones reutilizadas. También se requieren accesos sensibles/exportaciones controlados y auditados, y revisión de privacidad aprobada.

Orden sugerido de revisión

1. Confirmar definiciones de métricas y universos (puntos 1 y 4).
2. Cerrar matriz de roles/alcances y seguridad (puntos 6 y 8), prerrequisito para permisos del buscador y accesos sensibles.
3. Completar auditoría de operaciones y lecturas (punto 7).
4. Cerrar buscador, gestión de empresas y salud con esas reglas aplicadas (puntos 2, 3 y 5).
5. Ejecutar regresión integral y recorridos de navegador; registrar evidencia, límites y decisiones aprobadas.

La secuencia es una propuesta de trabajo, no un cambio automático de alcance. Cada requisito conserva su estado del SRS hasta que exista evidencia de sus criterios de aceptación o una decisión explícita sobre alcance.